TRB Review Intake Request

Document control	
Document ID	INT-TRB-2026-009
Document type	Review Intake Request
Date	2026-09-22
Status	Submitted
Review IDs	TRB-2026-009
Feature keys	MCP servers@Generative AI & Agents
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Submitter Information

Field	Value
Submitting Business Unit	Generative AI & Agents / Clinical Decision Support
Primary Contact	Chief Data Officer
Contact Email	cdo@acmehealthplan.com
Submission Date	September 22, 2026

Feature Information

Feature Name: MCP (Model Context Protocol) Servers

Feature Category: Generative AI & Agents

Databricks Release Phase: GA

Brief Description: Model Context Protocol (MCP) enables Databricks agents to call external APIs and tools via standardized interfaces. MCP servers are integrations with external systems (e.g., web APIs, internal databases). Acme Health Plan is evaluating

MCP to connect agents to clinical decision support tools and member eligibility systems.

Use Case and Business Justification

What problem does this feature solve for Acme Health Plan?

Clinicians and care managers need to answer questions like "Is this medication covered under the patient's plan?" or "What are the FDA-known interactions with this drug?" Currently, this requires manual lookup in multiple systems. Databricks agents with MCP servers could automate these lookups, improving clinical decision-making speed and accuracy.

Intended User Base:
- [ ] Analytics teams | [ ] Data engineers | [ ] CISO/Security | [x] Clinicians/Claims | [x] Other: Care managers, Pharmacy team

Expected Data Volume & Sensitivity:
- [x] 1M-10M rows
- PHI involved? [x] Yes | [ ] No
- Types: [x] Member demographics (member ID, plan) | [x] Claims data (coverage lookups) | [x] Clinical Notes (optional, for agent context) | [ ] Credentials | [ ] Genetic info | [ ] Other

---

Proposed Implementation

Timeline:
- Target start date: October 15, 2026 (initial MCP server setup)
- Target production date: January 2027 (phased rollout)

Scope:
- [ ] Pilot (≤5K rows, ≤90 days, non-PHI only)
- [x] Limited rollout (specific teams/regions)
- [ ] Full production rollout

Initial MCP Servers (Phase 1):
1. **FDA Drug Interaction API:** External API querying FDA database for drug-drug interaction warnings. Read-only. No PHI sent; only drug names queried.
2. **Internal Member Eligibility System:** Internal Acme Health Plan API (existing) returning member coverage info (plan type, covered services, limitations). Read-only. Member ID sent in query; receives coverage details.

Future MCP Servers (Phase 2, pending approval):
- Clinical guidelines database (internal or external)

- Provider network lookup
- Lab result integration

Dependencies:
- Databricks agent framework (available in GA)
- External API credentials (FDA API key; internal eligibility system auth token)
- Network connectivity from Databricks workspace to external APIs

---

Security & Compliance Scoping

Will this feature handle PHI?
[x] Yes | [ ] No | [ ] Uncertain

If yes, which categories:
[x] Member demographics (member ID, plan) | [x] Claims data (coverage lookups) | [ ] Clinical notes | [ ] Credentials | [ ] Genetic info | [ ] Other

Data Residency Requirements:
[x] On-premise | [x] AWS US-East | [ ] AWS region-specific | [ ] Multi-region | [ ] No requirement

Regulatory Triggers:
[x] HIPAA PHI handling (member ID / coverage info is PHI)
[x] Third-party data sharing (FDA API is external; need BAA clarification)
[ ] State data breach law | [ ] Cross-border transfer | [ ] None

---

Known Risks & Questions

What concerns do you anticipate?

1. **External API Security:** FDA Drug Interaction API is public (no auth required). Is it HIPAA-compliant? Databricks is sending drug names (not PHI), but are we exposing query patterns or member demographics indirectly?
2. **Internal API Authentication:** Member Eligibility System uses API key. If key is compromised, attacker could query all member coverage. Need to assess key rotation policy and scope (can the key query all members, or is it scoped?).
3. **MCP Server Audit Trail:** If agent calls an MCP server, is the request and response logged? By Databricks? By the external system? Needed for breach investigation.
4. **Error Handling:** If an MCP server returns an error, could it leak information (e.g., "Member ID 123 not found" vs. "Authentication failed")? Timing attacks?

5. **Data Retention:** External APIs may cache or log requests. Does FDA API store queries? Does Acme's internal eligibility system log who queried what member? TRB needs confirmation.

Which security controls are most critical?
- API authentication/authorization (API key security, scope)
- Data transmission encryption (TLS 1.2+)
- Audit logging (request, response, user, timestamp)
- Rate limiting (prevent abuse/scanning)
- Error messages (no data leakage)
- BAA confirmation (if external APIs handle PHI)

Documentation Provided

Attach or reference:
- [x] Architecture diagram: Agent → MCP Server → External API / Internal System (description provided in use case above; formal diagram to be provided during risk assessment)
- [x] Feature documentation: https://docs.databricks.com/en/generative-ai/model-context-protocol/
- [ ] Preliminary security assessment: (Will be completed during TRB review)
- [x] API documentation: FDA API at fda.gov; Internal Eligibility API documented in [Internal Wiki]
- [ ] BAA with external providers: (TBD—need to clarify if FDA API requires BAA)

Checklist for Completeness

- [x] All fields above completed
- [x] Use case justification is clear
- [x] Data scope is quantified (member ID + coverage info, not clinical notes in Phase 1)
- [x] Timeline is defined
- [x] Relevant documentation attached
- [x] Known risks identified

Submitter Certification:

I certify that the information provided above is accurate to the best of my knowledge, and I have authority to request this review on behalf of the Clinical Decision Support team.

Signature / Approval:
[CDO] — Title: Chief Data Officer
Date: September 22, 2026

For TRB Use Only

Field	Value
TRB Intake ID	TRB-2026-009
Date Received	September 22, 2026
Assigned Reviewer	[Enterprise Architect]
Scheduled for Review	TRBM-2026-09-22 (intake); full review TRBM-2026-10-09 (estimated)
Intake Status	[x] Complete

Classification: Internal – Synthetic Sample